

Annex B

OTShield Capability Profile & Live Threat-Intel Evidence

Supporting document to OTShield's HMGCC Co-Creation Proposal: Smart Personal Assistant for Security Researchers

This annex is **optional reference material** that provides supporting evidence for the dual-use claim already made and assessable within the six-page main proposal (Section 1 and Section 8). Per HMGCC Q&A (Q6), all assessable information is contained in the main proposal itself; this annex is provided only to give the reviewer faster verification of the live-platform numbers (157 attackers, 20 countries, 12,968 attacks) and the dual-use commercial framing, should they wish to verify those claims directly. Reading this annex is not required for evaluation. Summary: OTShield is a working ICS security platform with an internet-facing live threat-intel feed running today, and an active commercial pipeline targeting critical-infrastructure operators. We are pre-revenue: no paying customer is yet deployed, but the platform that HMGCC's Phase 1 funding extends is the same platform we are taking to market commercially, so HMGCC will not be a sole customer.

B.1 OTShield platform: live capabilities at a glance

Capability	TRL today	Evidence
Research Mode (Workbench)	TRL 3 to 4	Operational Bundles, Library, Summary, Inventory, Ports & Services, Threads, Findings, Vulns. Local LLM (Ollama, q4_K_M) running per-bundle technical summaries offline. The HMGCC Phase 1 work extends this baseline to TRL 6.
SOC Mode + Decoy fabric	TRL 5 (internet-exposed decoy fabric)	Realistic protocol-aware decoys for Modbus, S7Comm, EtherNet/IP, OPC UA, DNP3 and additional ICS protocols. Fake HMIs (Siemens WinCC, Rockwell, Schneider, Generic) running with full alarm trees, phase voltages, control breakers, refinery pipelines, water plants and substations. Deployed and continuously running on an internet-exposed decoy fabric operated by Safetech Global; not yet deployed inside a paying customer's environment.
PCAP & live network analysis	TRL 5	Purdue-aware deep-packet inspection, IOA detection, protocol distribution, top talkers, zone crossings (East-West vs. North-South). PCAP upload and live capture from network interface.
Asset inventory + Purdue topology	TRL 5	Auto-discovered PLCs, RTUs, HMIs, engineering workstations, SCADA, switches, routers, with risk scoring and Purdue-level mapping (L0 to L5). Demo scenario: phishing → engineering workstation → lateral movement → PI Historian → SCADA → PLC → pump actuator manipulation.
MITRE ATT&CK for ICS coverage	TRL 5	Attacker TTPs aggregated per attacker; behavioural fingerprints; campaign clustering; IOC export in JSON / CSV / plain formats with SIEM / TAXII / MISP push

Capability	TRL today	Evidence
		interfaces in the platform (production-grade TAXII / MISP push hardened in Phase 2). Full ATT&CK for ICS kill chain wired into the data model: initial access, execution, persistence, discovery, lateral movement, collection, command-and-control, inhibit response, impair process control, impact.
Alerts & incident triage	TRL 5	High-confidence signals from the deception layer ranked by severity; MTTA / MTTR metrics; CSV / XLSX / PDF export; integrated alert correlation, threat intelligence enrichment and threat hunting.
Live ICS threat-intel feed	TRL 5 (live, internet-exposed)	Internet-exposed decoy fabric operated by Safetech Global capturing real ICS-protocol attacks. See Section B.2 below for current numbers.

B.2 Live threat-intel evidence: real attackers, real ICS commands

OTShield operates an internet-exposed decoy fabric, capturing real ICS-protocol attacks. The numbers below are from the first days of live operation alone:

157	20	12,968	~ days
unique attackers	source countries	total attacks	live deployment window

Attacker profile mix

The captured traffic spans the full ICS attacker spectrum:

- **Script-kiddie / opportunistic scanners:** the majority of unique sources. Mass-scan tooling probing common ICS ports (502 Modbus, 102 S7, 44818 EtherNet/IP, 4840 OPC UA, 20000 DNP3) without protocol-aware payloads. These are valuable because they establish a baseline of internet noise against ICS-shaped decoys.
- **Advanced ICS-aware actors:** a smaller but operationally significant subset of attackers issuing genuinely protocol-aware commands. Examples observed in the live data include unauthorised write attempts, out-of-range values, interlock-override attempts, and reconnaissance commands such as *Remote System Discovery* and *Spoof Reporting Message* mapped to the MITRE ATT&CK for ICS framework. This is exactly the behaviour HMGCC researchers will encounter in real tear-downs.

Why this matters for the HMGCC challenge

1. **Dual-use evidence:** the platform is already operational against real ICS attacker traffic beyond any HMGCC use case. What the HMGCC funding extends is not a prototype written for this competition: it is a working platform that is capturing live attacker behaviour against an internet-exposed decoy fabric right now, on the same code base we are taking to commercial customers under three published price tiers.

2. **A real corpus the air-gapped tool can use:** the captured TTPs, IOCs and protocol-level commands feed directly into the trusted-source register and the verifier agent's knowledge of "what attackers actually do at this protocol level". For the air-gapped researcher tool, this material is delivered via signed update bundles (see Annex A.4): the laptop never connects to the internet, but it benefits from intel that internet-facing infrastructure has gathered.
3. **Sustained & refreshed:** the feed grows continuously while the decoy fabric is online. Phase 2 productionises this into a regular update cadence (signed bundles published on a fixed schedule), funded by Safetech Global's commercial roadmap as paying customers come on board, and available to HMGCC at no marginal cost.

B.3 Why this is fundamentally different from a RAG-only proposal

Some applicants to this challenge will deliver a fairly conventional document-Q&A system: drop documents in, ask questions, get answers grounded in the documents. That is RAG, and it is well understood.

OTShield's approach is qualitatively different because the existing platform brings two things a RAG-only system cannot:

- **Real network behaviour to validate against documentation.** When a vendor manual says "the device exposes Modbus on TCP/502 with read-only function codes", a RAG system can repeat that. OTShield can also run that claim against the captured PCAPs to confirm or refute it. Documentation is a starting point, not the truth.
- **Real attacker behaviour as a knowledge source.** When a researcher asks "what TTPs target this PLC family", a RAG system can summarise public advisories. OTShield can also surface the live, recent attacker behaviour observed against equivalent decoys, mapped to MITRE ATT&CK for ICS, with confidence scores and source citations.

This is why we describe the Phase 1 deliverable as *true analytical support*, not as a search tool: the assistant has access to evidence beyond the document corpus the researcher feeds it.

B.4 Commercial pipeline and target segments (dual-use proof)

OTShield is pre-revenue: we are not yet deployed inside a paying customer's environment. What we have today is (i) a working platform, (ii) an internet-exposed decoy fabric validating the deception layer against real attackers, (iii) three published commercial pricing tiers (see Annex E), and (iv) an active commercial pipeline of conversations with the segments below. The point relevant to HMGCC is that the same platform reaches more than one buyer, so HMGCC will not be a sole customer.

Segment	Status & notes
Critical-infrastructure operators (energy, water, transport, pharma)	Active commercial conversations via OTShield's pipeline. Target use case: deploying the Workbench inside the operator's air-gapped engineering environment for vendor product assessment and internal red-team work. No paying deployment yet; first contracts targeted in 2026.
UK national security & defence (beyond HMGCC)	Other UK government departments running ICS tear-downs and supply-chain assurance: MOD, NCSC, NPSA, defence prime contractors' security functions. Same Phase 1 capability, different customer.
ICS vendor red teams & product security	Internal red teams at Siemens-, Rockwell-, Schneider-class vendors run product-security tear-downs today on ad-hoc tooling. OTShield is a

Segment	Status & notes
	structured replacement.
International allies	Five Eyes & NATO partner governments doing equivalent ICS assurance. Phase 2 onwards.

B.5 Roadmap and sustainability beyond Phase 1

OTShield's roadmap beyond Phase 1 is funded by Safetech Global's continued commercial investment in the platform, with paying revenue expected to ramp in 2026 as the segments above convert. HMGCC's £60k Phase 1 contribution is leveraged against:

- Continued operation of the internet-exposed decoy fabric and threat-intel feed.
- Hardening and certification of the Workbench beyond TRL 6.
- Ongoing protocol-extractor library updates as new ICS protocols emerge.
- Phase 2 features (collaborative multi-researcher workspaces, hardware-in-the-loop firmware extraction).

The practical meaning of "commercially supported tool, not a one-off bespoke build": the platform exists for reasons beyond HMGCC, the maintenance burden does not fall on HMGCC, and the Phase 1 royalty-free licence to HMGCC remains in place regardless of how the commercial pipeline converts.